

Data Retention and Disposal Policy

LAST UPDATED: AUGUST 18, 2026

This policy defines how long MĪZAN retains consumer data, when and how that data is deleted, and how compliance with applicable data-protection laws (GDPR, CCPA, and equivalents) is maintained. It applies to all consumer data obtained via Plaid, SnapTrade, and related providers, and to the operator's own administrative records.

1. Purpose

To minimize data exposure by retaining consumer financial data only for as long as required to deliver the service, to enable consumers to exercise their right of erasure, and to ensure that retained data is disposed of securely when no longer needed.

2. Scope

- All consumer data stored in the Supabase project, including authentication records, profile data, Plaid tokens, account metadata and transactions, SnapTrade user records, budgets, goals, audit logs, and net-worth history.
- Operational records that contain consumer identifiers (Sentry error events, Vercel logs, Resend email logs).
- Backups maintained by infrastructure vendors (Supabase, Vercel).

3. Data Categories and Retention Periods

The schedule below reflects the live database schema. Where a row says "until account deletion", the data is removed automatically by cascading foreign keys when the account

is deleted (see §4.2).

Category	Storage	Retention
Authentication credentials (hashed password, MFA factors)	Supabase Auth (<code>auth.users</code>)	Until account deletion
User profile (email, name, preferences)	<code>profiles</code>	Until account deletion
Plaid access tokens	<code>plaid_tokens</code>	Until institution disconnect or account deletion; revoked at Plaid via <code>/item/remove</code>
Plaid account metadata (institution, mask, balances)	<code>plaid_accounts</code> (RLS-protected)	Until institution disconnect or account deletion
Plaid transactions	<code>plaid_transactions</code> (RLS-protected)	Stored. Until institution disconnect or account deletion. Synced incrementally so budgets and spending history persist.
SnapTrade user-id / user-secret pair	<code>user_snaptrade</code> (encrypted at rest)	Until account deletion
SnapTrade holdings / activities	Not stored — live pass-through	Zero retention
Budgets (amounts assigned, rollover flags, monthly income)	<code>budget_entries</code> , <code>budget_months</code>	Until account deletion
Savings goals and debts	<code>goals</code> , <code>user_state</code>	Until account deletion
Net-worth history snapshots	<code>user_state</code>	Until account deletion

Category	Storage	Retention
Account nicknames	<code>account_nicknames</code>	Until account deletion
Support messages	<code>messages</code>	Until account deletion
Product usage counters (per-section view counts)	<code>nav_usage</code>	Until account deletion. Counters only — no timeline, no financial data, no IP or device details.
Trading-bot strategies and pending signals (beta feature)	<code>bot_strategies</code> , <code>pending_signals</code> , <code>account_full_auto</code>	Until account deletion
Audit log entries	<code>audit_log</code>	Minimum 12 months; reviewed during policy review
Security events (IP blocks, failure tracking)	<code>security_events</code>	Rolling; purged by the daily cleanup job
Web push subscriptions	<code>push_subscriptions</code>	Until the user unsubscribes or the account is deleted
Cached market data	<code>polygon_cache</code> , <code>etf_holdings_cache</code> , <code>purification_ratios</code>	Rolling cache, evicted by TTL; contains no consumer identifiers
Rate limit counters	<code>rate_limits</code>	Rolling buckets; oldest rows evicted automatically
Scheduled job heartbeats	<code>cron_jobs</code>	Operational only; no consumer identifiers
Runtime error events	Sentry (PII scrubbed)	30–90 days per Sentry's retention tier
Function logs	Vercel	Per Vercel's plan-level retention
AI Assistant messages	Not stored by MĪZAN	Zero retention on our side; subject to Anthropic's own policy in transit

4. Deletion Triggers and Mechanisms

4.1 User-initiated institution disconnect

1. Calls Plaid's `/item/remove` endpoint, revoking the access token on Plaid's side.
2. Deletes the corresponding row from `plaid_tokens`.
3. Deletes all rows from `plaid_accounts` and `plaid_transactions` for that institution.
4. Writes a `bank.disconnect` entry to `audit_log`.

4.2 User-initiated account deletion

1. All rows referencing the user's `user_id` are cascade-deleted via Postgres `ON DELETE CASCADE` foreign-key constraints. Every table listed in §3 that is scoped to a user is covered.
2. Plaid `/item/remove` is called for each linked institution to revoke access tokens upstream.
3. SnapTrade `/snapTrade/deleteUser` is called to remove the user's record on SnapTrade.
4. The Supabase Auth record is deleted via the admin API.

4.3 Data-subject erasure requests

Erasure requests under GDPR, CCPA, or equivalent statutes are honored within 30 days of receipt. Requests are routed to khanstyle02@gmail.com (also published in the [Privacy Policy](#)). The operator verifies the request originates from the account holder, then triggers the same account-deletion flow described in §4.2 and confirms completion in writing.

4.4 Automatic eviction

- Cache tables are evicted by a TTL field and rebuilt on demand.
- `rate_limits` buckets are overwritten in place; older buckets are evicted by the daily cleanup job.
- The daily cleanup job also purges aged `audit_log` and `security_events` rows beyond their retention window.

5. Disposal Standards

- Database deletions execute as standard SQL `DELETE` against Supabase Postgres, which marks rows for vacuuming by the underlying engine. Vacuum overwrites the row's storage location with new data on subsequent writes; no row content is preserved.
- Supabase maintains point-in-time-recovery backups for a rolling window. On account deletion, residual copies of consumer data in these backups age out within that window. No restore-from-backup is performed against a deleted account.
- Plaid access tokens are revoked at Plaid via `/item/remove` before local deletion, so even a stale token cannot be used post-deletion.
- Audit log entries are purged when their owning user account is deleted (cascade), or, where retained for compliance, after the 12-month minimum has elapsed and no active investigation references them.

6. Vendor Data Handling

The following processors retain copies of consumer data under their own retention policies, summarized here for transparency:

- **Supabase** — primary store; subject to the deletion mechanisms above. Backups age out per Supabase's backup window.
- **Plaid** — retains access tokens until `/item/remove` is called, then per Plaid's End User Data Protection schedule.
- **SnapTrade** — retains the SnapTrade user record until `/snapTrade/deleteUser` is called.
- **Anthropic** — receives portfolio context only when the user sends a message to the AI Assistant; retention per Anthropic's own policy. MĪZAN stores no Assistant conversation history.
- **Sentry** — retains scrubbed error events per Sentry's plan-level retention (30–90 days typical); no consumer financial data is sent.
- **Vercel** — retains function logs per its plan-level retention; logs do not include consumer financial data.

- **Resend** — retains transactional email metadata for delivery troubleshooting per Resend's policy.

7. Legal Hold

If the operator receives a lawful preservation order, subpoena, or written notice of pending litigation referencing specific consumer data, the affected records are excluded from the routine deletion processes above until the legal hold is lifted. Holds are documented as `legal.hold` entries in `audit_log` with the date, the requesting authority, and the scope of the preserved data. No legal holds are active at the publication date of this policy.

8. Compliance and Review

This policy is designed to meet the obligations of the GDPR (right to erasure, storage limitation), the CCPA/CPRA (right to delete, data minimization), and equivalent state and national statutes. It is reviewed **quarterly**, and whenever a schema or vendor change alters what is stored. The review is triggered automatically from this document's own review date rather than relying on memory.

9. Contact

Retention or deletion questions: khanstyle02@gmail.com.